

Improper access control in team management in [berriai/litellm](#)

✓ Valid

Reported on Apr 9th 2024

Description

There are many access control vulnerabilities in team management. These vulnerabilities allow attacker to create/update/view/delete/block/unblock any teams and add/delete any member to/from any teams.

Details

delete any team

```
@router.post(
    "/team/delete", tags=["team management"], dependencies=[Depends(user_api_key_auth)]
)
async def delete_team(
    data: DeleteTeamRequest,
    user_api_key_dict: UserAPIKeyAuth = Depends(user_api_key_auth),
):
    global prisma_client

    if prisma_client is None:
        raise HTTPException(status_code=500, detail={"error": "No db connected"})

    if data.team_ids is None:
        raise HTTPException(status_code=400, detail={"error": "No team id passed in"})

    ## DELETE ASSOCIATED KEYS
    await prisma_client.delete_data(team_id_list=data.team_ids, table_name="key")
    ## DELETE TEAMS
    deleted_teams = await prisma_client.delete_data(
        team_id_list=data.team_ids, table_name="team"
    )
    return deleted_teams
```

add any user as admin to team

```
@router.post(
    "/team/member_add",
    tags=["team management"],
    dependencies=[Depends(user_api_key_auth)],
)
async def team_member_add(
```

```

data: TeamMemberAddRequest,
user_api_key_dict: UserAPIKeyAuth = Depends(user_api_key_auth),
):
    if prisma_client is None:
        raise HTTPException(status_code=500, detail={"error": "No db connected"})

    if data.team_id is None:
        raise HTTPException(status_code=400, detail={"error": "No team id passed in"})

    if data.member is None:
        raise HTTPException(status_code=400, detail={"error": "No member passed in"})

    existing_team_row = await prisma_client.get_data( # type: ignore
        team_id=data.team_id, table_name="team", query_type="find_unique"
    )

    new_member = data.member

    existing_team_row.members_with_roles.append(new_member)

    complete_team_data = LiteLLM_TeamTable(
        **existing_team_row.model_dump(),
    )

    team_row = await prisma_client.update_data(
        update_key_values=complete_team_data.json(exclude_none=True),
        data=complete_team_data.json(exclude_none=True),
        table_name="team",
        team_id=data.team_id,
    )

    ## ADD USER, IF NEW ##
    user_data = { # type: ignore
        "teams": [team_row["team_id"]],
        "models": team_row["data"].models,
    }
    if new_member.user_id is not None:
        user_data["user_id"] = new_member.user_id # type: ignore
        await prisma_client.update_data(
            user_id=new_member.user_id,
            data=user_data,
            update_key_values_custom_query={
                "teams": {
                    "push": [team_row["team_id"]],
                }
            },
            table_name="user",
        )
    elif new_member.user_email is not None:
        user_data["user_id"] = str(uuid.uuid4())
        user_data["user_email"] = new_member.user_email
        ## user email is not unique acc. to prisma schema -> future improvement
        ### for now: check if it exists in db, if not - insert it
        existing_user_row = await prisma_client.get_data(
            key_val={"user_email": new_member.user_email},
            table_name="user",
            query_type="find_all",

```

```

    )
    if existing_user_row is None or (
        isinstance(existing_user_row, list) and len(existing_user_row) == 0
    ):

        await prisma_client.insert_data(data=user_data, table_name="user")

    return team_row

```

Proof of Concept

```
curl --location 'http://localhost:4000/team/delete' --header 'Authorization: Bea
```

```
curl -X POST 'http://localhost:4000/team/update' -H 'Authorization: Bearer sk-EDPWe
```

Impact

These vulnerabilities allow attacker to create/update/view/delete/block/unblock any teams and add/delete any member to/from any teams.

Occurrences

 proxy_server.py L6095-L6133

 proxy_server.py L6533-L6559

 proxy_server.py L6388-L6456

 proxy_server.py L6594-L6596

 proxy_server.py L6616-L6618

 proxy_server.py L6293-L6343

 proxy_server.py L6186-L6251

 proxy_server.py L6490-L6495

 We are processing your report and will contact the **berriai/litellm** team within 24 hours. 2 years ago



 **huntr-helper** modified the Severity from Critical (10) to Critical (9.1) 2 years ago



 **fewword** modified the report 2 years ago

 We have contacted a member of the **berriai/litellm** team and are waiting to hear back 2 years ago



fewword commented 2 years ago

Researcher

Hi Huntr Admin Team,

I'm currently in communication with a project maintainer regarding a vulnerability I reported. They've encountered an issue where they are unable to create additional keys to access the report details after going to the link provided by Huntr. They mentioned: "when going to the link they shared, we were unable to create additional keys - as our db auth checks this."

Could you please provide some guidance or steps on how the project maintainer can overcome this hurdle to access the report? Any insight or assistance would be greatly appreciated to help resolve this matter smoothly.



fewword modified the report 2 years ago



Ishaan Jaff commented 2 years ago

Maintainer

To do any of these actions you need to be authenticated into the proxy server

```
dependencies=[Depends(user_api_key_auth)],
```



A **berriai/litellm** maintainer has acknowledged this report 2 years ago

The scheduled publication date was automatically extended from 25th May 2024 to 1st Jun 2024 due to the maintainers acknowledgement of the report 2 years ago



Ishaan Jaff modified the Severity from Critical (9.1) to None (0) 2 years ago

★ The researcher has received a minor penalty to their credibility for miscalculating the severity: -1



✗ **Ishaan Jaff** has marked this vulnerability as not applicable 2 years ago

To do any of these actions you need to be authenticated into the proxy server

\$ The disclosure bounty has been dropped ✗

\$ The fix bounty has been dropped ✗

★ The researcher's credibility has decreased: -5



fewword commented 2 years ago

Researcher

hi maintainer, in my poc

```
curl --location 'http://localhost:4000/team/delete' --header 'Authorization: Bearer sk-EDPWei
```

Authorization: Bearer sk-EDPWeidMYhR87NOwUwoR6g this is user api-key and this stands for user1 that admin created



Ishaan Jaff commented 2 years ago

Maintainer

Authorization: Bearer sk-EDPWeidMYhR87NOwUwoR6g

You're authenticated into the proxy to do this action ^



fewword commented 2 years ago

Researcher

yes, even user1 is not the member in this team, he can also delete this team by this api in my poc



fewword commented 2 years ago

Researcher

hi Ishaan Jaff

could you re-evaluate this vulnerability report?

A huntr admin reset this report to a pending state. 2 years ago



fewword modified the report 2 years ago



Ishaan Jaff modified the Severity from Critical (9.8) to Medium (5.7) 2 years ago



Ishaan Jaff commented 2 years ago

Maintainer

- user interaction is required since the team member needs to be given a key to access the proxy in the first place



fewword commented 2 years ago

Researcher

Hi@Ishaan Jaff, thank you for reviewing the CVSS score I assigned to the vulnerability. I would like to address some points regarding your modifications:

User Interaction: According to NIST, user interaction is defined as a scenario where successful exploitation of a vulnerability requires a user to perform specific actions (like clicking a link in an email) before it can be exploited. In this case, obtaining the key does not necessitate any actions from a third party, therefore, I believe user interaction should not be considered.

Privileges Required: The definition by NIST states that the attacker does not require any access to settings or files to carry out an attack if unauthorized before the attack. In our scenario, the attacker only needs authentication, which does not equate to having low privileges or authorized access to specific settings or files necessary for the attack. Thus, I argue that this should not be classified under low privilege.

Impact on Integrity and Availability: The issues extend beyond information disclosure, affecting various functionalities in team management such as unauthorized modification, deletion, and addition of data. This compromises both the integrity and availability, suggesting that the impact is significant and should not be classified as 'none.' I hope we can reassess these points to ensure the CVSS score accurately reflects the potential impact of the vulnerability.

Thank you for your consideration



Ishaan Jaff commented 2 years ago

Maintainer

requires a user to perform specific actions (like clicking a link in an email)

The Admin has to actively decide to give someone access to the proxy by creating an API key for them. I kindly request you try using LiteLLM before commenting on vulnerabilities.
<https://docs.litellm.ai/>



fewword commented 2 years ago

Researcher

Thank you for your feedback. I want to clarify that I have set up a local Docker environment where I have tested and successfully exploited all reported vulnerabilities. If necessary, I can provide a screen recording to demonstrate the exploits.

Regarding your statement that "The Admin has to actively decide to give someone access to the proxy by creating an API key for them," I interpret this to mean that an admin creates a user, but the operations that this user can perform are significantly fewer than those available to an admin. If this interpretation is correct, then the attack does not require a third party to click a link to be exploited; it only requires the user created by the admin to execute a curl command.

Please let me know if my understanding aligns with your intentions, or if further clarification is needed.



 **fewword** modified the report 2 years ago

 **Marcello** modified the Severity from Critical (9.8) to Medium (6.5) 2 years ago

Marcello commented 2 years ago

Admin

Hey @Ishaan,

As per my previous comment, regardless of whether or not this does require an API key we'd still consider this a security issue.

Thanks.



fewword commented 2 years ago

Researcher

Hey @Marcello,

Thank you for your efforts in manually reviewing my report. I noticed that the CVSS score has been adjusted from 9.8 to 6.5, and I have some concerns regarding the changes. Specifically, the "Privileges Required" has been marked as "high," but the vulnerability I reported can be exploited by any user with standard user privileges. Additionally, the "Availability" metric was set to "none," despite the vulnerability allowing attackers to delete, update, block, or unblock teams, which clearly impacts availability. Could you please clarify the reasons for these adjustments?

Thanks.

Marcello commented 2 years ago

Admin

Hey @fewword,

I think you might be misunderstanding how LiteLLM works here. Unless you've setup SSO from my understanding any key you generate through the UI will have admin access and it is expected behavior that an admin would be able to update/delete teams and their members.

Have you setup LiteLLM with SSO? can you provide some evidence that a non-admin user can indeed perform these actions?

Thanks.



fewword commented 2 years ago

Researcher

Hey @Marcello,

from my understanding any key you generate through the UI will have admin access Regarding the point about each key having admin access, I believe there might be a misunderstanding. The keys I am referring to were generated through the /user/new API endpoint, which by default creates users with the role of app_user, not proxy_admin. The app_user role, as designed, should not have admin-level access to update or delete teams and their members. This behavior suggests a potential permission escalation issue that allows app_user roles to perform actions typically reserved for admins. Could you please verify this functionality? I am happy to provide further details or assistance to clarify this issue.

Thank you for looking into this.

Marcello commented 2 years ago

Admin

Hey @fewword,

Please provide a step-by-step on how to do the following:

- how you created the user with the `app_user` role
- How you authenticate to litellm with that user.

I tried doing this myself and received the following error:

```
{"error":{"message":"Authentication Error, Only proxy admin can be used to generate, delete, upda\n```\n
```



fewword commented 2 years ago

Researcher

Hey @Marcello,

This is the poc video.

(https://drive.google.com/file/d/105QjmEwAFIhvBZn_xvLLNh07T1wTJVL/view?usp=drive_link)



fewword modified the report 2 years ago



fewword commented 2 years ago

Researcher

Any update?



fewword commented 2 years ago

Researcher

? ? ? ? ? ? ?

We have sent a warning to the **berriai/litellm** team to inform them that this report will be published in 48 hours 2 years ago

Marcello set the scheduled publication date to Jun 16th 2024 UTC 2 years ago

Marcello modified the Severity from High (8.1) to Medium (5.3) 2 years ago

The researcher has received a minor penalty to their credibility for miscalculating the severity: -1

Marcello validated this vulnerability 2 years ago

fewword has been awarded the disclosure bounty

The fix bounty is now up for grabs

The researcher's credibility has increased: +7

CVE-2024-5710 assigned to this report. 2 years ago

We have sent a warning to the **berriai/litellm** team to inform them that this report will be published in 48 hours 2 years ago

This vulnerability has now been published 2 years ago

CVE-2024-5710 has now been published 2 years ago

Krish Dholakia commented 2 years ago

Maintainer

Hey team, this is NOT a current vulnerability in LiteLLM (1.40.29). Your issue is old. We request you test on latest before publishing vulnerabilities.

Please see the attached screenshot - https://drive.google.com/file/d/1Mu4PxOc-HLlml-zUdF_x4it45BWMLt77/view?usp=sharing

[Sign in](#) to join this conversation

CVE

CVE-2024-5710

Published

Vulnerability Type

CWE-862: Missing Authorization

Severity

Medium (5.3)

Attack vector	Network
Attack complexity	High
Privileges required	Low
User interaction	None
Scope	Unchanged
Confidentiality	None
Integrity	High
Availability	None

[Open in visual CVSS calculator](#) 

Registry

Pypi

Affected Version

1.34.34

Visibility

Public

Status

Awaiting fix

Disclosure Bounty

\$125 to \$300

Fix Bounty

\$31.25

Found by



fewword

@fewword

MIDDLEWEIGHT





© 2024

[Privacy Policy](#)

[Terms of Service](#)

[Code of Conduct](#)

[Cookie Preferences](#)

[Contact Us](#)